

IT Security Basics

Cryptography and Digital Signatures

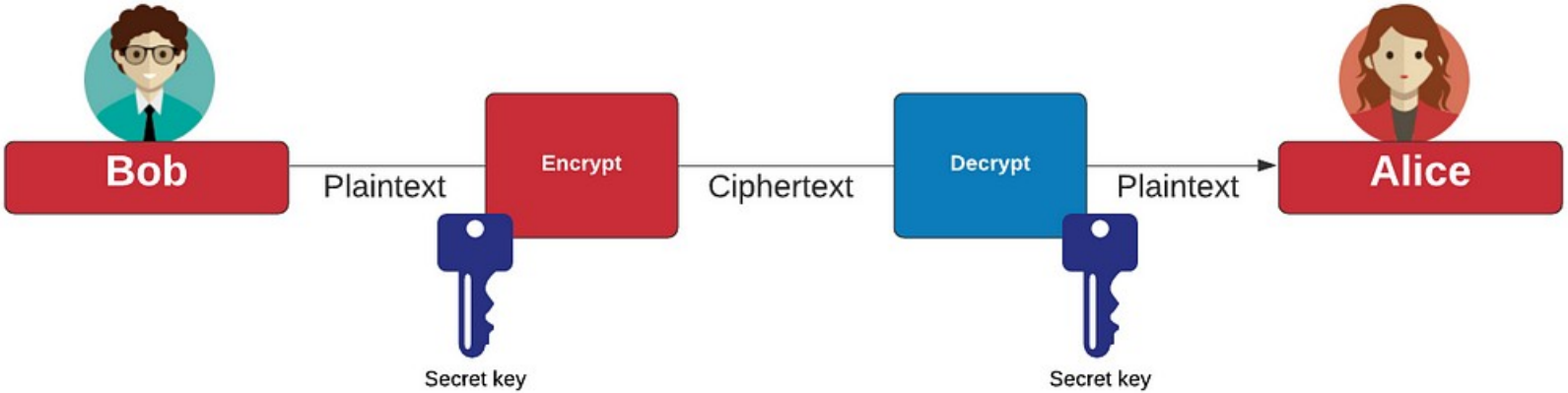
Overview

- **Cryptography**
  - Encryption of information (= secret writing)
- **Cryptanalysis**
  - Research into cryptographic methods
  - Application of methods for breaking cryptographic procedures
- **Cryptolinguistics**
  - Examination of language features
- **Steganography**
  - Hiding of information – no real cryptography

Basics

- **Alphabet**
  - Finite amount of characters available for composing a message
- **Plaintext**
  - The message M to be encrypted
- **Ciphertext**
  - The encrypted message C
- **Encryption function**
  - E = (M, K_E) With key K_E
- **Decryption function**
  - D = (C, K_D) With key K_D

Basics



Source: https://medium.com/asecuritysite-when-bob-met-alice/everything-you-want-to-know-about-aes-but-were-afraid-to-ask-b46165410ea8

Security Goals

- **Confidentiality**
  - Keeping information hidden from everyone except those authorized
- **Integrity**
  - Ensuring the message hasn’t been altered during transmission
- **Authenticity**
  - Verifying that the message comes from a trusted source
- **Interoperability**
  - Cryptography allows for secure communication between different systems and platforms

Kerckhoff Principle

- 19th century principle formulated by the Dutchman A. Kerckhoffs

The security of an encryption method is based solely on the secrecy of the key and not on the secrecy of the encryption algorithm.

- Reasons:
  - Keys can be kept secret better than algorithms
  - Keys can be exchanged better than algorithms
  - Keys are easier to manage than algorithms

- Contrast: Security through obscurity (= no security)
  - „Security“ through secrecy of the encryption algorithm itself

Requirements for encryption procedures

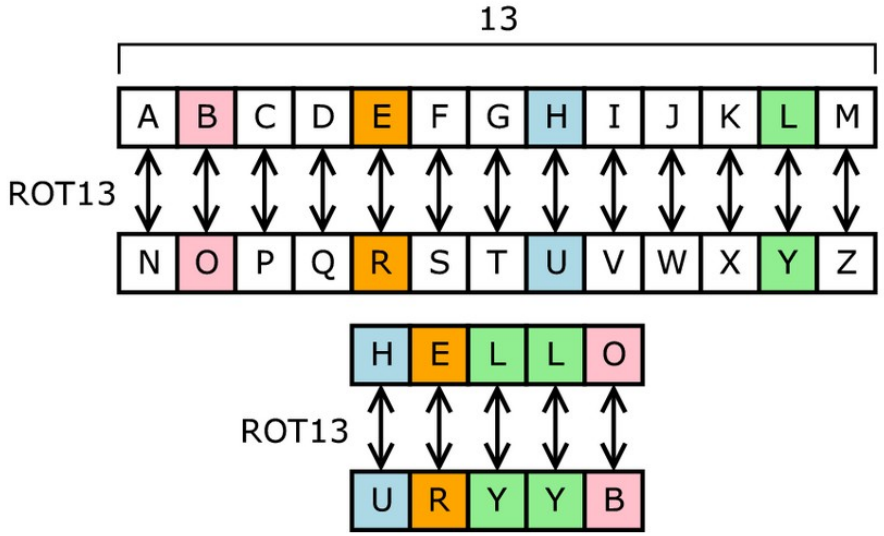
- Claude Shannon 1949:
  - **Diffusion**
    - Dispersion of the structure (e.g. by transposition or permutation)
    - Small change in plaintext => big effect in ciphertext
    - Statistical analysis is made more difficult
  - **Confusion**
    - Complexity between key and ciphertext as large as possible
    - It must not be possible to derive the key simply from ciphertext
    - e.g. by means of substitution mechanisms

Basics Principles

FH University of Applied Sciences TECHNIKUM WIEN

Substitution - Caesar Shift

- Substitution = Each character of the plaintext alphabet is mapped to a character of the ciphertext alphabet
- One of the oldest and well known encryption = Caesar Shift
- Used in Windows OS till vers
  - https://blog.didierstevens.com/2009/01/18/quickpost-windows-7-beta-rot13-replaced-wi vigenere-great-joke/
- Only shifting characters in the alphabet
  - The number of characters you sh is the key → not secure since onl 26 possible keys
  - Key in ROT13: 13



Transposition

- Basically: Change the position of the letters in the text
- Examples:
  - Switching Columns and rows
  - Using a key (shown in the image)

Encryption

Given text = Geeks for Geeks

Keyword = HACK **Length of Keyword** = 4 (no of rows) **Order of Alphabets in HACK** = 3124

H	A	C	K
3	1	2	4
G	e	e	k
s	_	f	o
r	_	G	e
e	k	s	_

Print Characters of column 1,2,3,4

Encrypted Text = e kefGsGsrekoe_

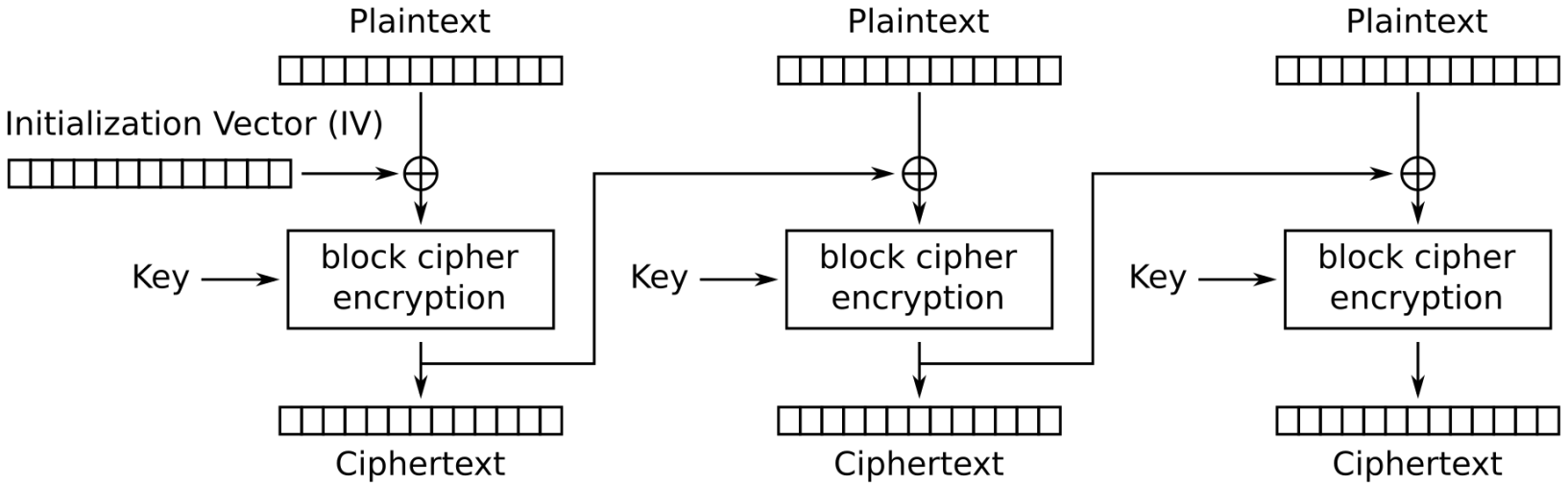
Source: https://cyberw1ng.medium.com/an-overview-of-columnar-transposition-cipher-features-encryption-and-decryption-2023-d5d07655af74

Block Cipher

- Divide the plaintext into blocks of a certain size before encryption
- Each block has identical sizes in plaintext and ciphertext
- Blocks are encrypted with a secret symmetric key
- Different modes possible:
  - If each block is encrypted independently of the others, this is called ECB mode – rarely used
  - CBC Mode uses feedback (XOR linking of an encrypted block with the next block to be encrypted)
  - CFB encrypts the previous ciphertext and XORs the result with the current plaintext block.

- Popular Block Cipher:
  - AES Algorithm
  - Triple DES

Block Cipher

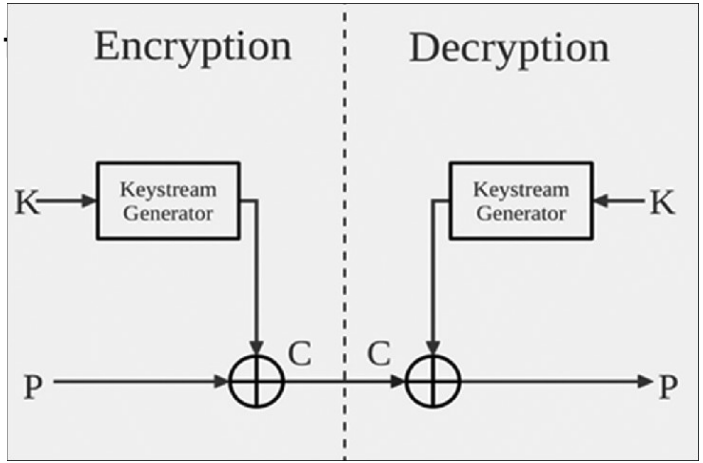


Cipher Block Chaining (CBC) mode encryption

Source: https://en.wikipedia.org/wiki/Block_cipher_mode_of_operation#/media/File:CBC_encryption.svg

Stream Cipher

- Encryption function generates a pseudo-random key stream of arbitrary length, which is XORed with the plaintext.
- Each bit is encrypted individually, you don't have to wait for filled blocks (therefore faster)
  - e.g.: WLAN RC4 (WEP), GSM: A5 algori



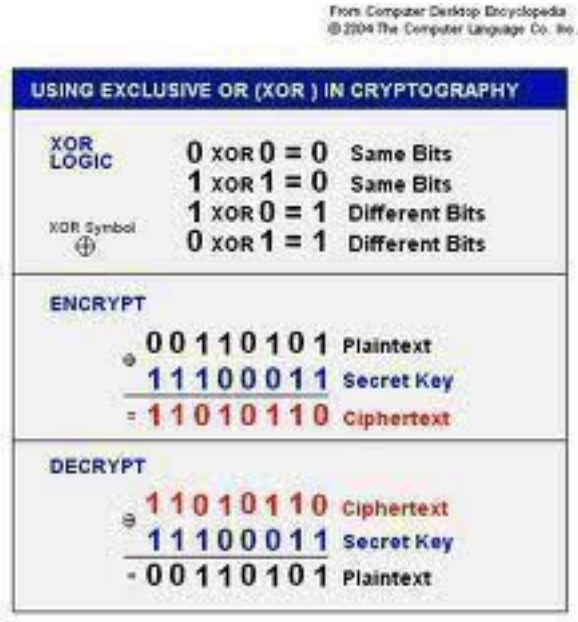
Source: https://www.researchgate.net/figure/Stream-cipher-diagram_fig2_318517979

Stream Cipher – one time pad

- Special form of stream cipher

- Unreservedly safe if
  - Key length= length of the plaintext
  - Key a real, random string
  - Single use of the key

- Not practice-oriented
  - Double the amount of data necessary
  - Key exchange
  - Quantum Cryptography

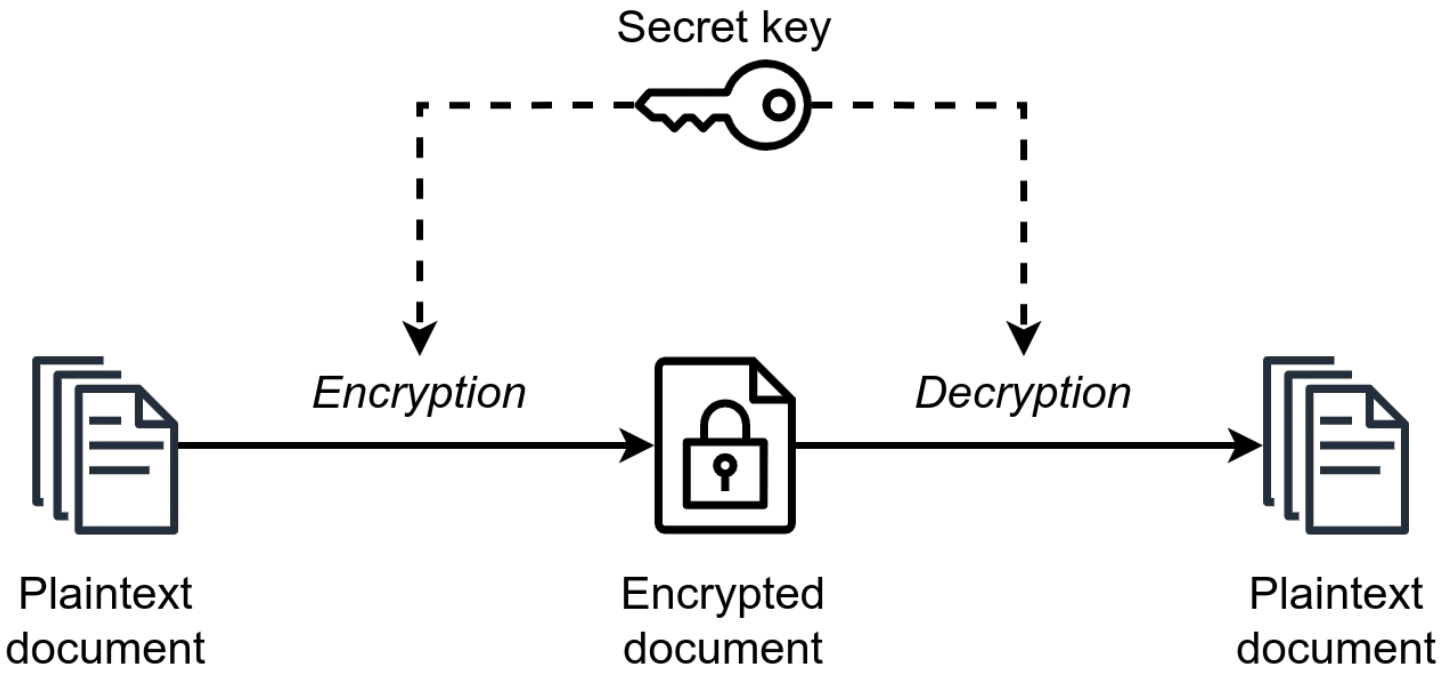


Source: https://www.tech-faq.com/xor-encryption.html

Symmetric Cryptography

FH University of Applied Sciences TECHNIKUM WIEN

Symmetric Encryption



Source: https://en.wikipedia.org/wiki/Symmetric-key_algorithm#/media/File:Simple_symmetric_encryption.png

Symmetric Cryptography

- The same key is used to decrypt and encrypt a message
- Base Symmetric cryptography: Block cipher
  - Encrypts block by block with symmetric key

- Common symmetric encryption methods:
  - AES
  - Triple DES / 3DES

- Old and not longer secure methods:
  - DES
  - RC4

Symmetric Cryptography

- Advantages
  - „CPU near“ operation
  - Quick
  - Short keys
  - Good to exchange big amount of data / huge data
  - Efficient to implement in hardware (memory and energy consumption)

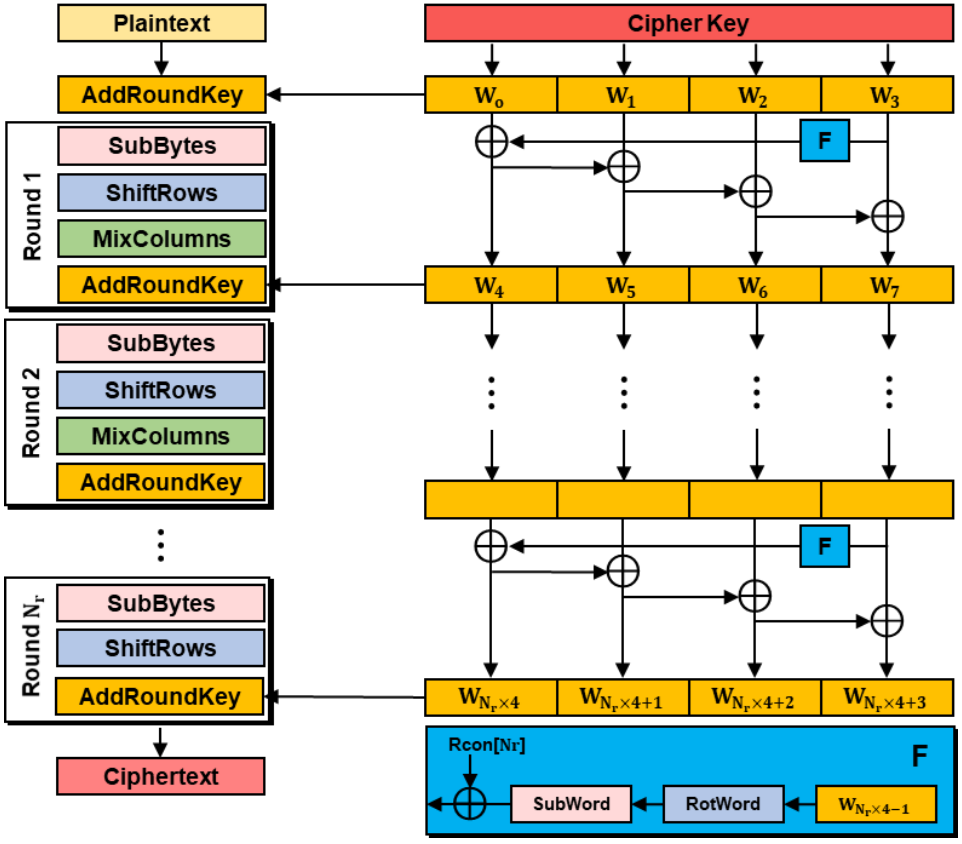
- Disadvantages
  - Problem: How to distribute or exchange the shared key with regard to confidentiality and authenticity

Symmetric Cryptography – Algorithms

- Triple DES (3DES):
  - Applies the today unsecure DES algorithm three times in a row
  - Security: 3DES offers stronger security but is slower and less efficient.
  - Still used in legacy systems, especially in financial services
- Advanced Encryption Standard (AES):
  - AES replaced DES and 3DES
  - Most widely used symmetric encryption algorithm today
  - Uses block sizes of 128 bits and key sizes of 128, 192, or 256 bits – nearly impossible to brute force
  - Why the key length matters?
    - Let’s say we’re using RSA with a 128-bit key. To break this encryption through brute-force, an attacker would have to test 2^{128} possible keys. Even with a supercomputer, this process would take billions of years!

Example: AES

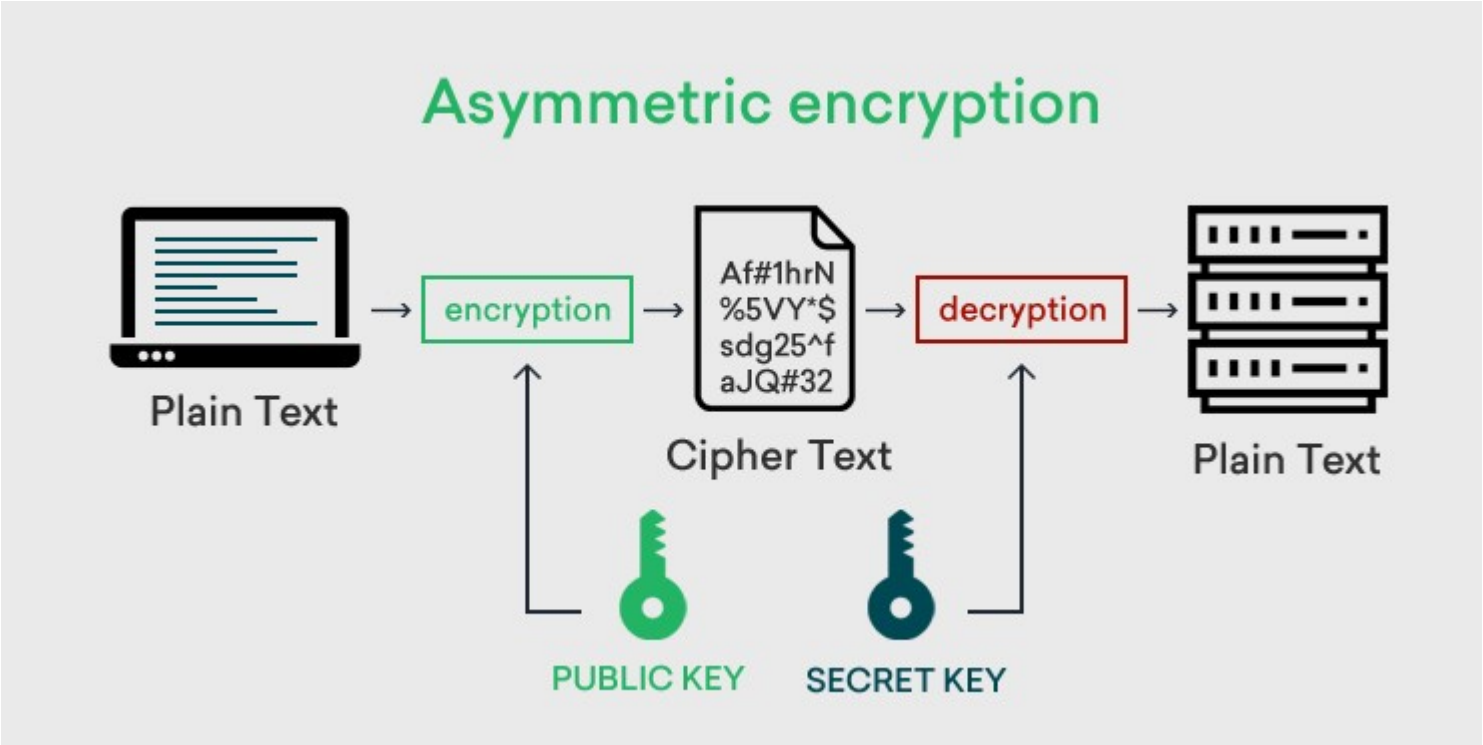
- Interested in how AES works step by step?
- Visit: https://legacy.cryptool.org/en/cto/aes-animation
  - Detailed animation and explanation of each step of the algorithm



Asymmetric Cryptography

FH University of Applied Sciences TECHNIKUM WIEN

Asymmetric Encryption



Source: https://www.clickssl.net/wp-content/uploads/2019/12/asymmetric-encryption.jpg

Asymmetric Cryptography

- Also called: public-private key encryption
- Uses two different keys for encryption (public key) and decryption (private key)

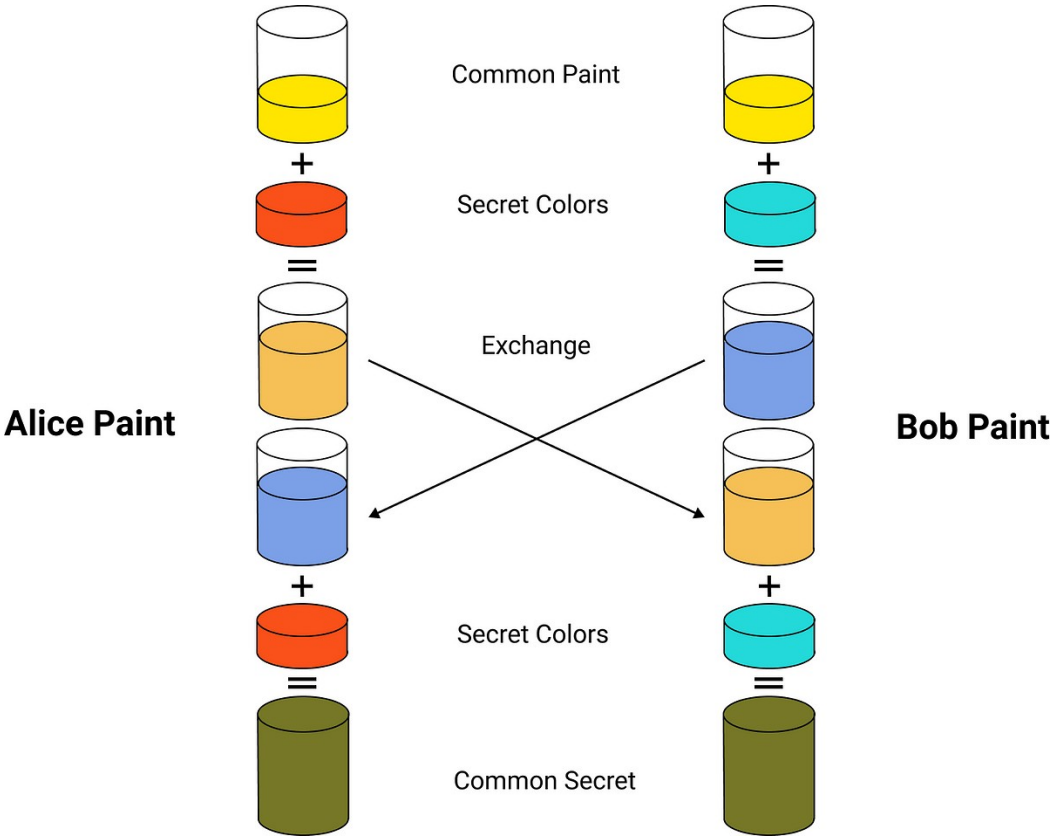
- Common asymmetric encryption methods:
  - RSA
  - Elgamal
  - Elliptic Curve Cryptography
  - Diffie Hellman

Asymmetric Cryptography

- Advantages:
  - Solves the problem of key distribution when using symmetric cryptography

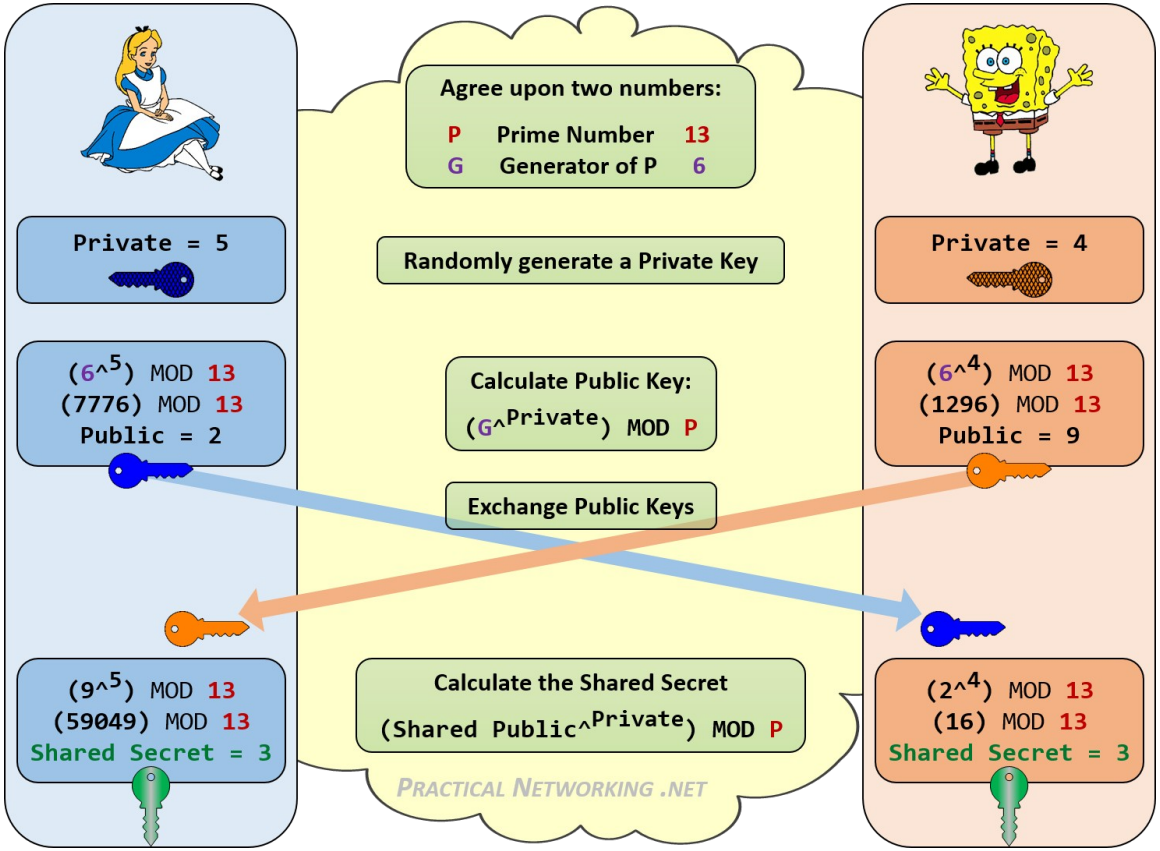
- Disadvantages:
  - Slower
  - Less efficient – needs more resources
  - More complex

Diffie Hellman



Source: https://miro.medium.com/v2/resize:fit:1200/1*DTAGyFXi1-x_TNxnpaeqZw.png

Diffie Hellman



Source: https://observablehq.com/@glennhenshaw/cryptography

Asymmetric Cryptography - RSA

- Most popular asymmetric algorithm: RSA
- Developed by Rivest, Shamir and Adleman in 1977
- Until today one of the most wide spread methods
- The keys are the products of two very large prime numbers. This makes it extremely difficult to infer the two prime numbers used (prime factorization)
- Key lengths should be at least 2048 bits, even though 1024 bits are still used today

Hybrid Cryptography

FH University of Applied Sciences TECHNIKUM WIEN

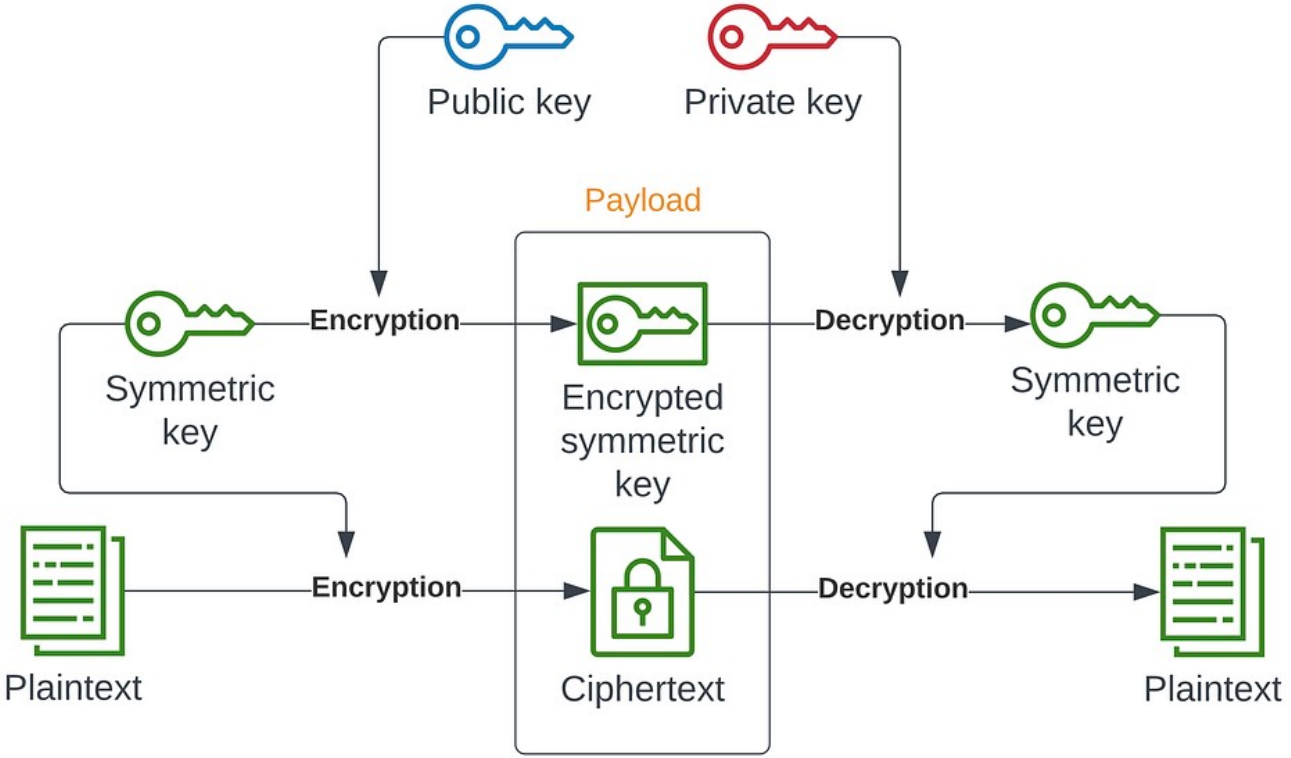
Hybrid Cryptography

- Combination of asymmetric and symmetric encryption for a secure and efficient communication

- Steps:
  - Asymmetric encryption to transmit the symmetric key in a secure way
  - Symmetric encryption for the rest of the communication for best performance

- Side effect: Authenticity

Hybrid Encryption



Source: https://medium.com/@igorfilatov/hybrid-encryption-in-python-3e408c73970c

Digital Signature

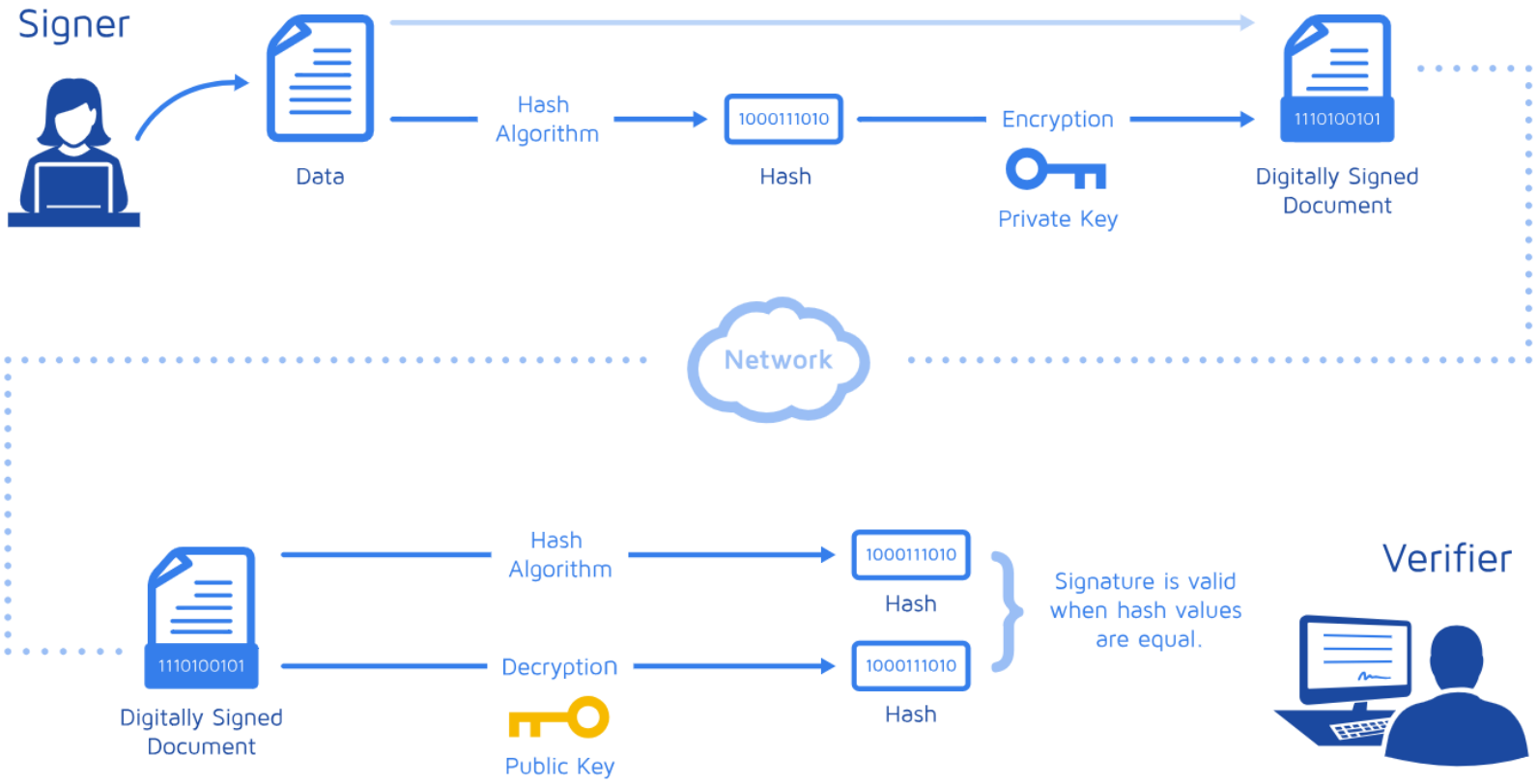
FH University of Applied Sciences TECHNIKUM WIEN

Digital Signature

- Purpose: Protection of integrity and non-repudiation
  - Checks the identity of the sender
  - Ensures that the data has not been modified (or added) in transit

- The private key of the sender is used for signing
- The recipient can use the public key of the sender to check the validity of the signature

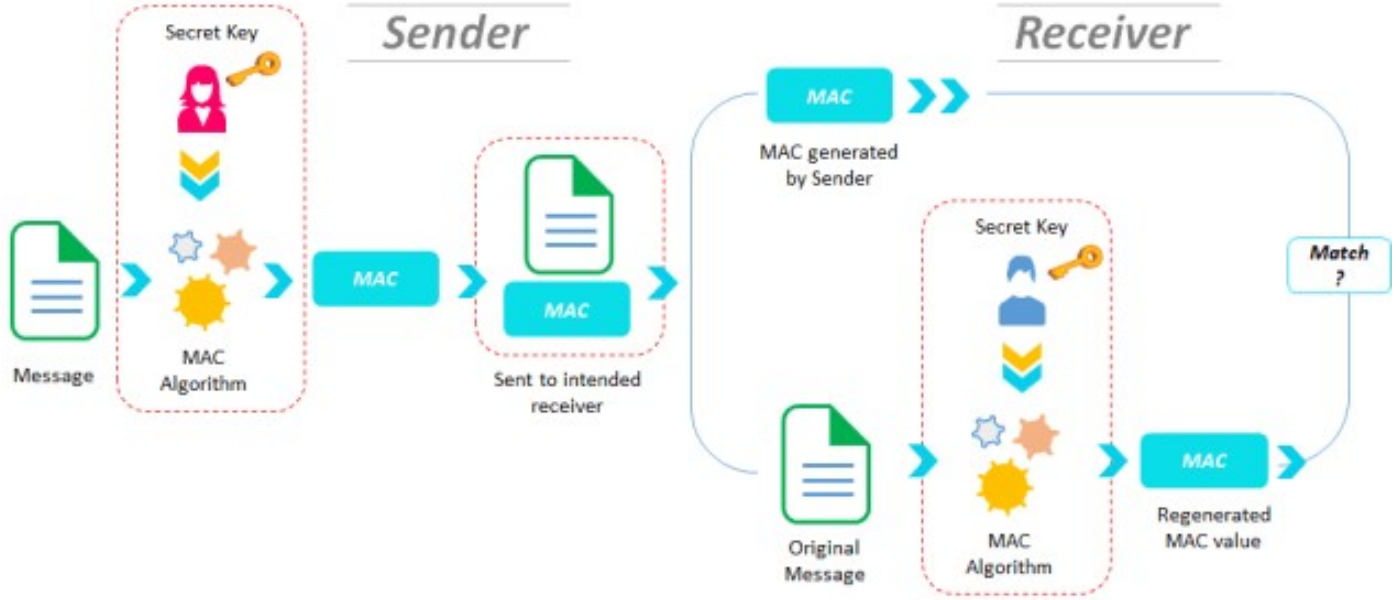
Digital Signature



Example: MAC

- Ensures authenticity of sender and the integrity of the message at the same time
- Requirements:
  - Sender and recipient share a symmetrical secret key
- Uses a complex a mathematical function to generate a MAC out of a message and secret key
  - Only the same message + secret key combination generates the same MAC
- When a hash-function is used, it is called HMAC

Example: MAC



Source: https://cryptopurview.com/exchanging-sensitive-information-using-message-authentication-code/